# Firewall Policy Complexity: From Simple ACLs to Least Privilege Network Access

BACSE203 Computer Networks · Fall 2026 · Case Study (Topic 17)


**Ramsrivathsan R**
25BCE2111

**S Darshan**
25BCE2883

**M B Adavan**
25BCE0063

**Naveen V S**
25BCE0059

**Himaneesh S**
25BAI0007


PERMIT DENY


School of Computer Science and Engineering, VIT Vellore

# Agenda

| | | | |
|---|---|---|---|
| 1 | Part A | **Review paper** | Problem, five literature themes, research gaps |
| 2 | Part B | **Design** | Requirements, network, three policies, test method |
| 3 | Part B | **Results** | Stage-by-stage evidence, metrics, key findings |
| 4 | Part C | **Alignment** | Comparison with the literature, limitations, future work |

# The problem we studied

### Broad rules are easy, but open

Most small networks let every department reach every server. One router ACL can close those paths.

### Strict rules are safe, but costly

Each step towards least privilege adds rules, conditions and rule-order dependence, which the literature links to errors.

**Research question**

*How does refining network access policy from broad, to department-level, to service-level least privilege change (a) the unnecessary flows the policy allows and (b) the policy's size, specificity and dependence on rule order, and how do these results compare with the literature?*

SECURITY COST measured together, on one network

# Objectives

### Build

A multi-department network in Packet Tracer; confirm every test flow works with no ACLs

### Specify

Write the required and forbidden flows before writing any rule

### Implement

Three policy stages at the same seven enforcement points

### Measure

Unnecessary access left, and policy size, specificity and rule-order dependence

### Stress

Design two typical policy mistakes (shadowed rule, missing DNS rule)

### Compare

Relate the results to the literature reviewed in Part A

# What the literature says (Part A)

### Perimeter filtering

Default deny at the boundary; inside often trusted

[3], [6], [7]

### Policy anomalies

First-match order causes shadowing and redundancy

[9]–[12]

### Growth & misconfiguration

Real rule sets are often wrong; complexity tracks risk

[1], [2], [13]

### Least privilege & Zero Trust

No trust from location; segment to limit lateral movement

[4], [5], [14]–[16]

### Management tools

Detect or prevent anomalies; usability rarely tested

[10]–[13], [17]

# Gaps we found, and our response

1. Empirical data on misconfiguration are dated and from few sources
2. Unnecessary access is rarely measured against written requirements
3. Security gain and management cost are seldom measured on the same policy
4. Management tools are seldom evaluated with real users

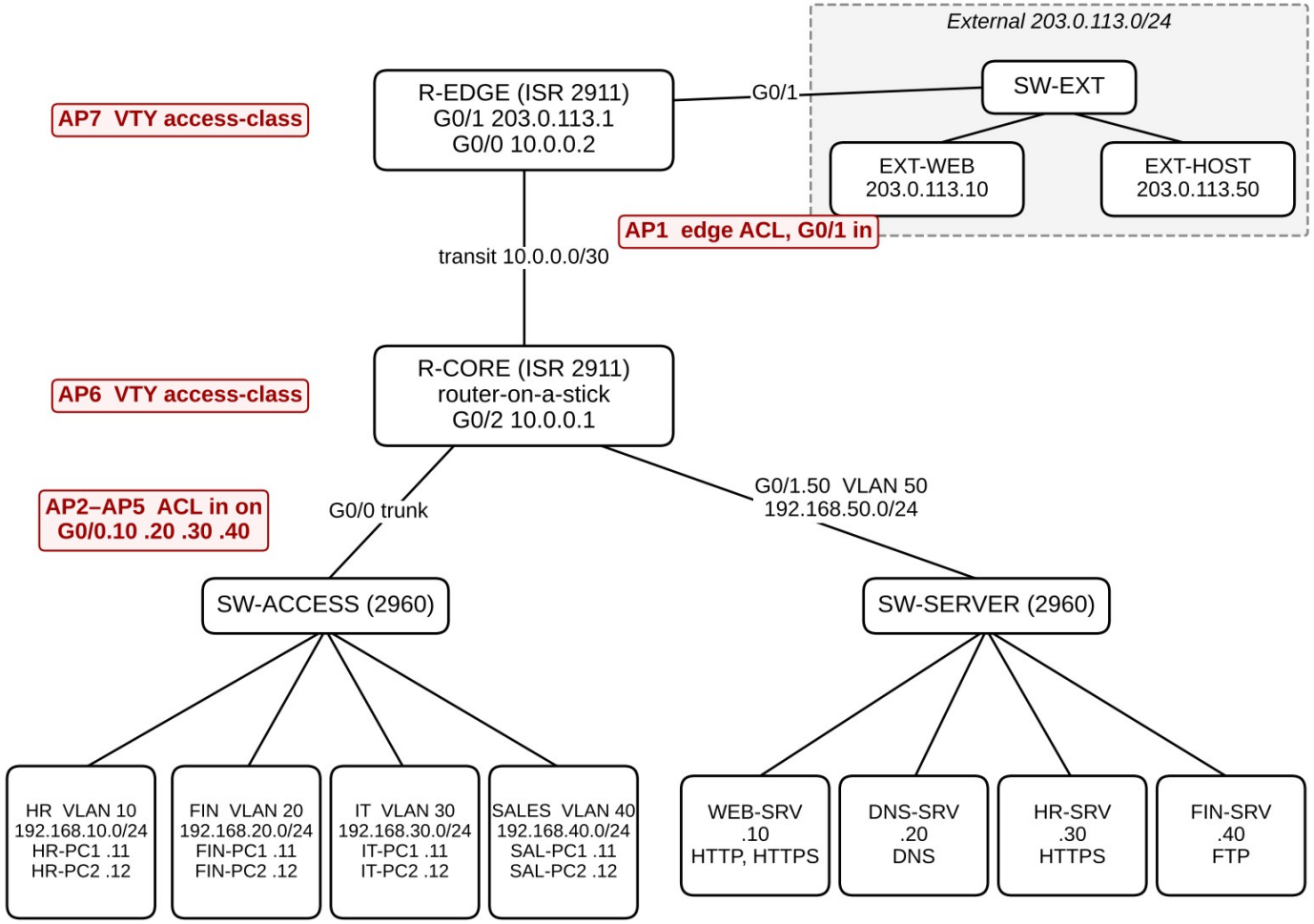
## Our response to gap 3

Write required and forbidden flows first.

Apply three policies of increasing precision to one network.

Measure leakage and policy size at every stage.

# Network design: 19 devices, 7 enforcement points




### 4 departments

HR, Finance, IT, Sales: VLANs 10–40

### 4 servers

Web, DNS, HR records (HTTPS), Finance (FTP)

### Simulated Internet

203.0.113.0/24 (RFC 5737)

### 7 enforcement points

Edge ACL, 4 department ACLs, 2 router logins

# Requirements written before any rule

**REQUIRED**

| | |
|---|---|
| **R1** | All departments → DNS server (UDP 53) |
| **R2** | All departments → web portal (HTTP/HTTPS) |
| **R3** | HR → HR records server (HTTPS) |
| **R4** | Finance → finance server (FTP) |
| **R5** | IT → both routers (SSH) |
| **R6** | IT → servers (ping) |
| **R7** | All departments → Internet web |
| **R8** | Internet → public web portal |

**FORBIDDEN**

| | |
|---|---|
| **X1** | Department → other department |
| **X2** | Non-HR → HR records server |
| **X3** | Non-Finance → finance server |
| **X4** | Non-IT → router management |
| **X5** | Anyone → routers by Telnet |
| **X6** | Non-IT → servers by ping / unused ports |
| **X7** | Internet → anything except the portal |

*U1: PC-to-PC traffic inside one VLAN cannot be filtered by a router ACL.*
*"Unnecessary access" = any X flow the policy still allows.*

# Three policies of increasing precision

Stage 1

## Broad

Any internal source → any destination; only the Internet edge filtered

**10 rules**

Stage 2

## Department-level

Own department → whole server zone and Internet; other departments denied

**25 rules**

Stage 3

## Least privilege

Each department → exact host, protocol and port it needs; SSH only for IT

**40 rules**

*Stage 0 (no ACLs) is the positive control: every test must work before any rule is applied.*

# What a least-privilege ACL looks like

```
ip access-list extended ACL-HR-IN
 permit udp HR host DNS-SRV eq domain          R1
 permit tcp HR host WEB-SRV eq www             R2
 permit tcp HR host WEB-SRV eq 443             R2
 permit tcp HR host HR-SRV eq 443              R3
 deny   ip  HR 192.168.0.0/16                  X1–X6
 permit tcp HR any eq www                      R7
 permit tcp HR any eq 443                      R7
 deny   ip  any any
```

### Host + protocol + port

Each permit names exactly what one requirement needs

### Order matters

The internal deny must stay above the Internet permits, or HR can reach any internal host on 80/443

### 24 such pairs

In Stage 3, 24 rule pairs would change behaviour if swapped

# Test method

**1**

### Write flows

8 required, 7 forbidden, 1 uncontrollable

**2**

### Build Stage 0

All 17 tests must work

**3**

### Apply stage

Paste ACLs on both routers

**4**

### Run same 17 tests

Same PCs, same order

**5**

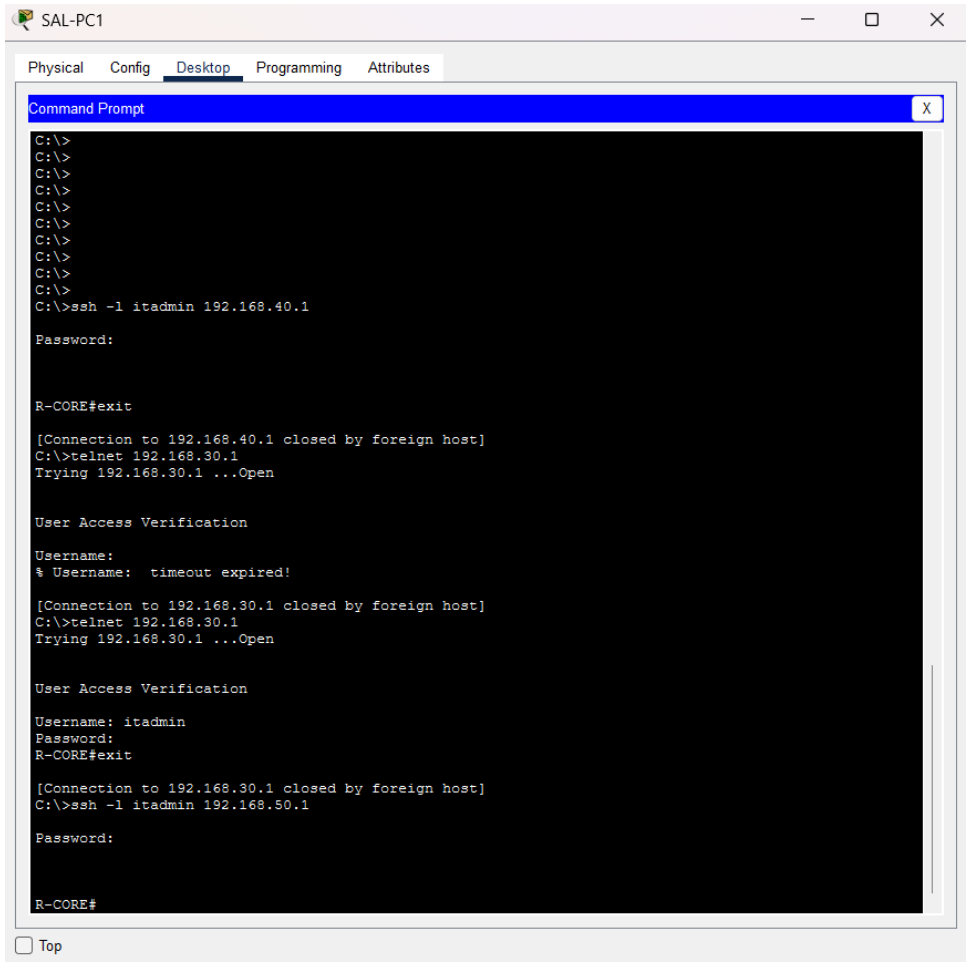
### Record evidence

Screenshots and ACL counters

### Metrics fixed before any result

- Leakage = forbidden tests that succeeded ÷ forbidden tests evidenced
- Required success = required tests that succeeded ÷ required tests evidenced
- Policy size, rule specificity and order-dependent rule pairs, from the configurations

# Stage 0: the network works with no rules




## Positive control: 17 of 17 reachable

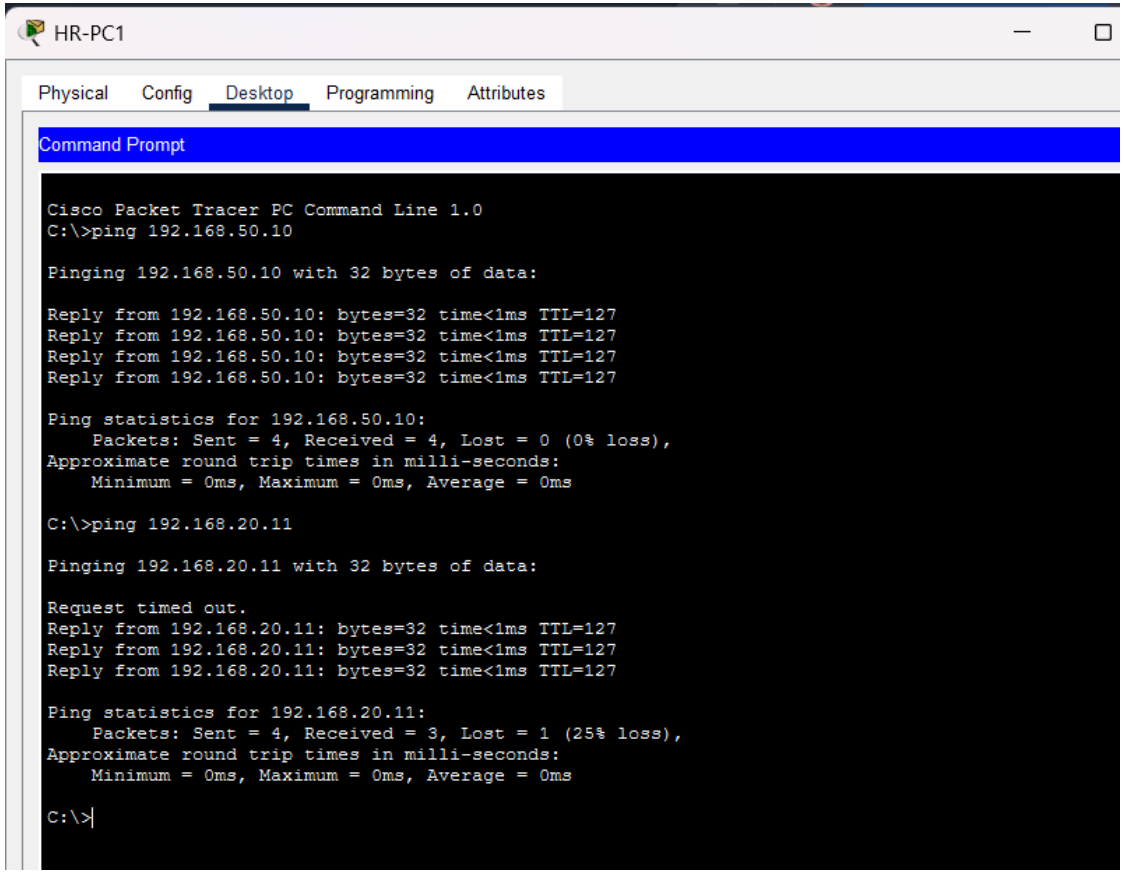
Every test, even the forbidden ones, worked with no ACLs. So any later block is caused by the policy, not by a broken cable or a stopped service.

## Faults found and fixed during the build

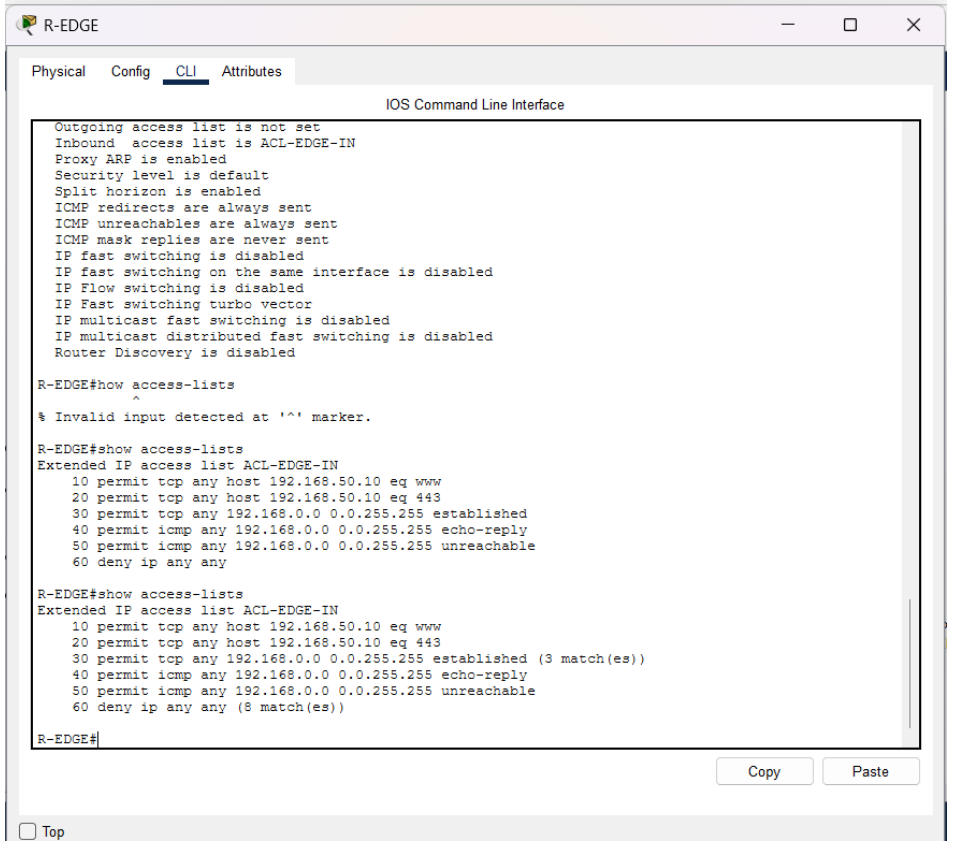
- R-CORE G0/1 had R-EDGE's address 203.0.113.1, which blocked external traffic
- DNS-SRV and EXT-WEB first had wrong IP addresses
- Two tests ran from a different PC than planned (T05, T12)

# Stage 1 (broad): the inside stays open

**PERMIT** HR pings a server (T13) and a Finance PC (T07): both forbidden, both work

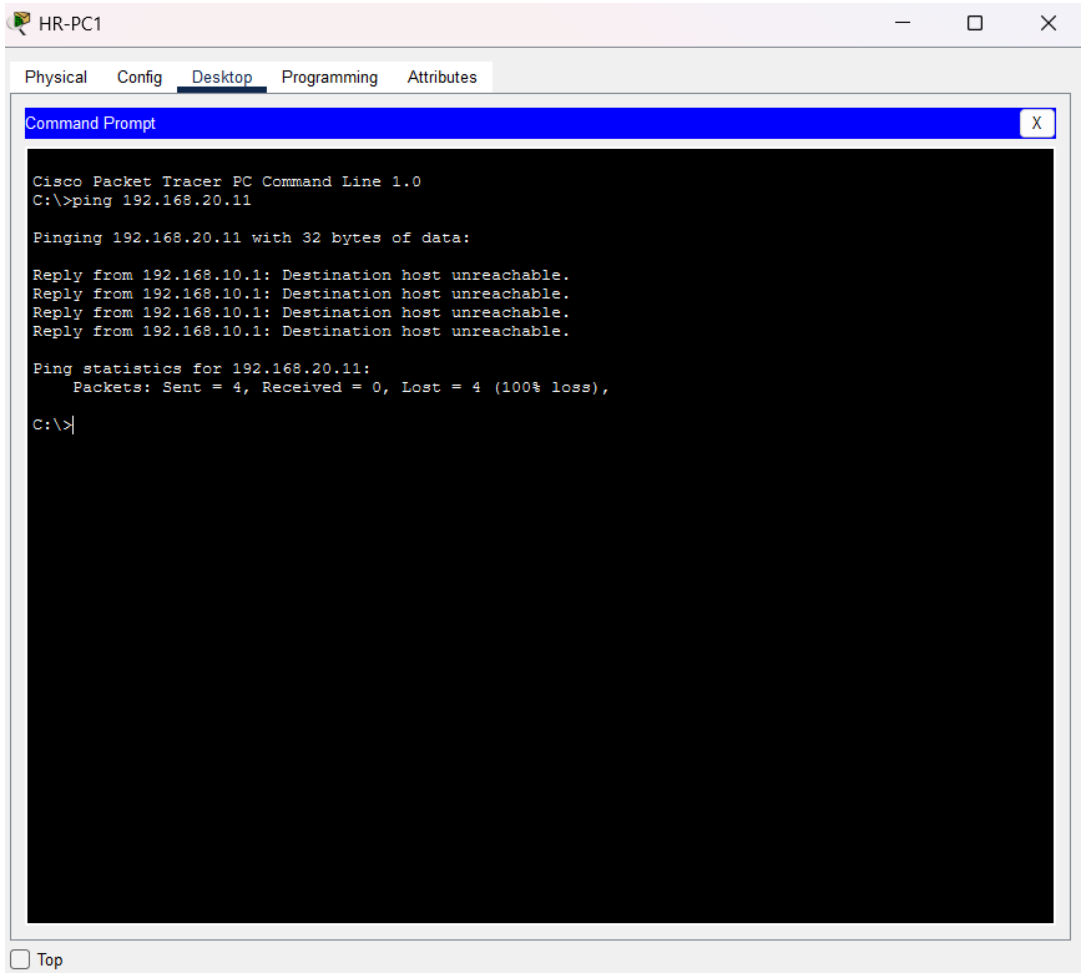



**COUNTERS** Edge ACL: return traffic matched 3×, deny matched 8×

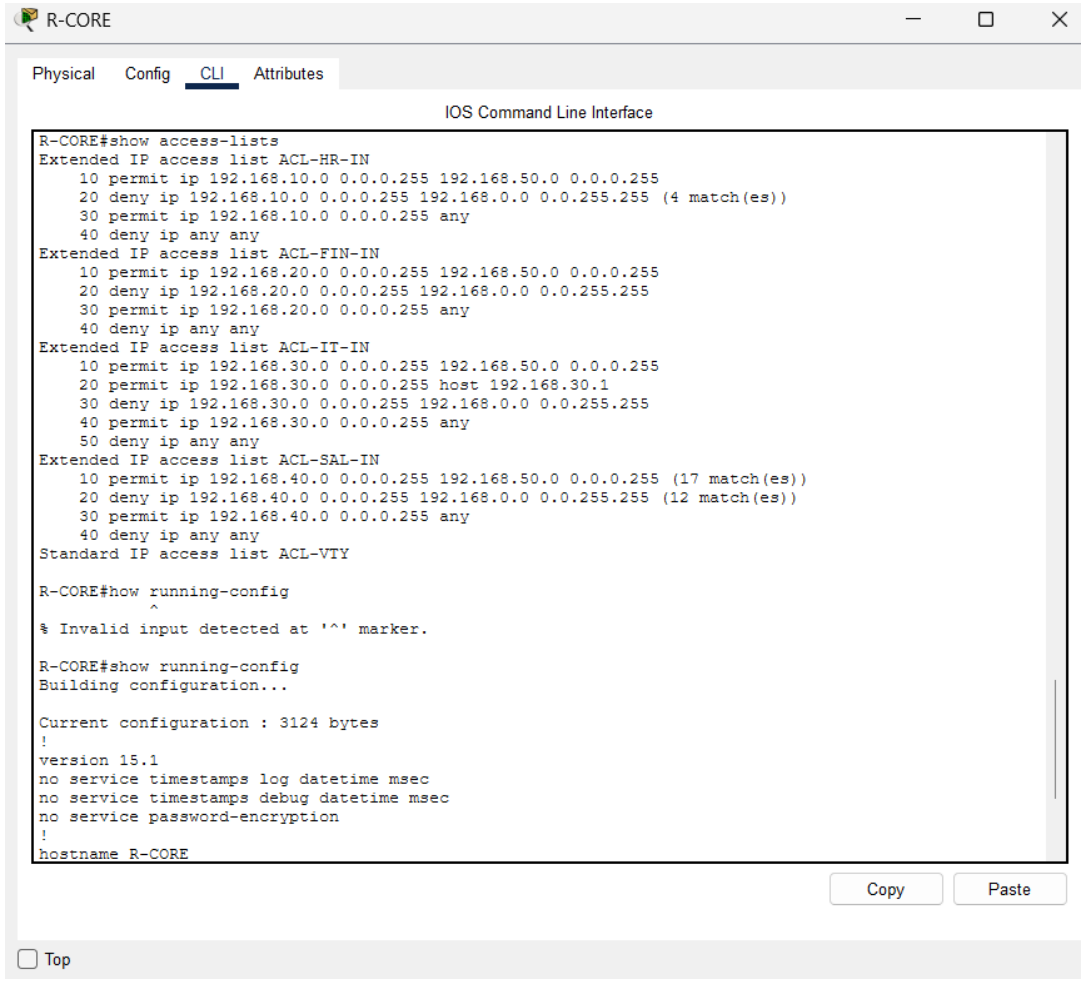


# Stage 2 (department-level): departments separated

**DENY** HR → Finance PC now blocked (T07)




**COUNTERS** One ACL per department; deny entries count hits



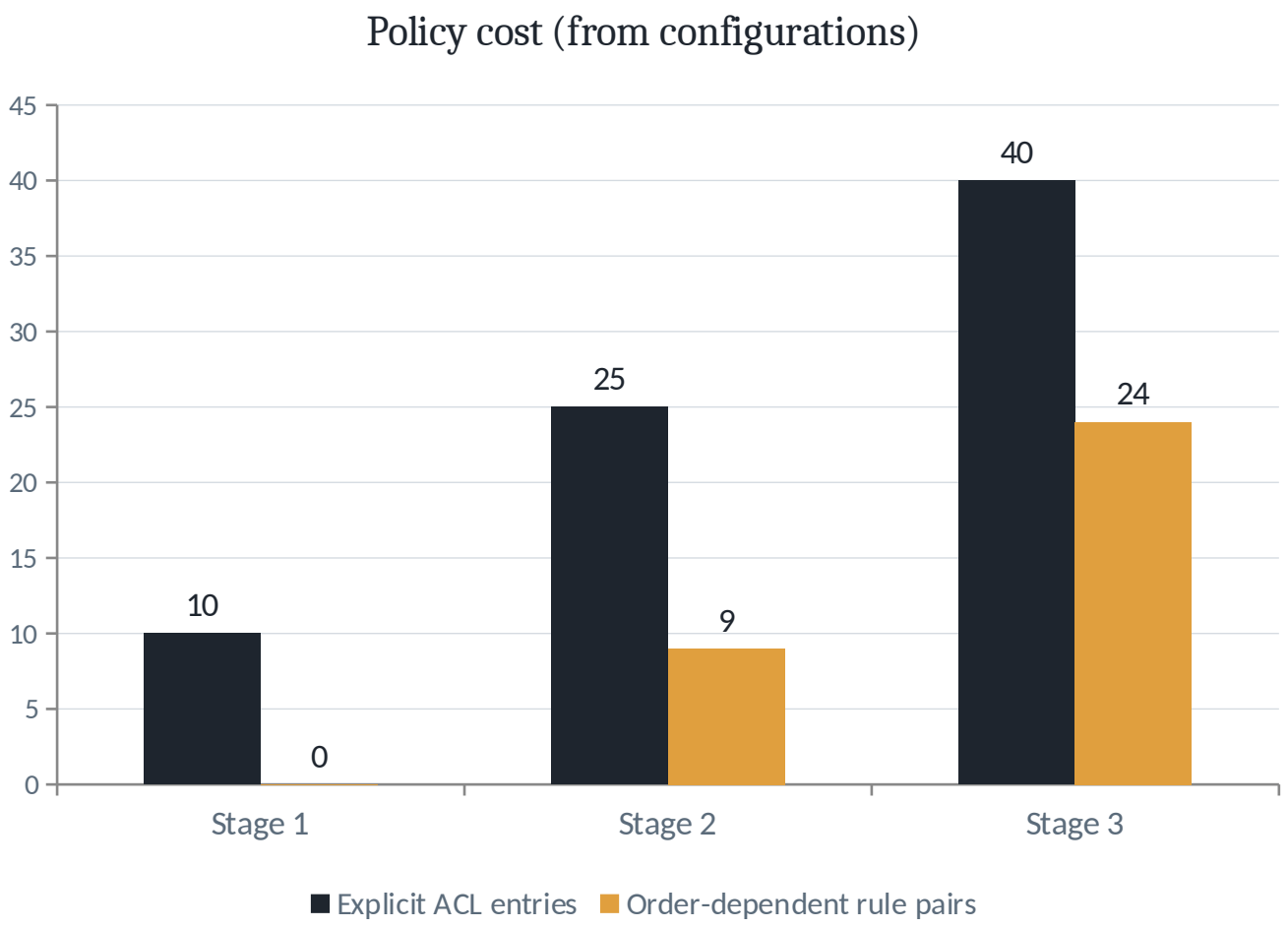
# All observed results

| Test | Flow | Type | S0 | S1 | S2 | S3 |
|---|---|---|---|---|---|---|
| T01 | HR → web portal | Req | A | A | A | A |
| T03 | HR → DNS | Req | A | n/e | A | n/e |
| T04 | Finance → FTP | Req | P | n/e | n/e | P |
| T05 | HR → HR records | Req | A | n/e | n/e | A |
| T06 | IT → router SSH | Req | A | n/e | n/e | A |
| T14 | IT → ping server | Req | A | n/e | A | n/e |
| T15 | Internet → portal | Req | A | n/e | A | n/e |
| T17 | HR → Internet web | Req | A | A | A | n/e |
| T07 | HR → Finance PC | Forb | A | A | D | D |

| Test | Flow | Type | S0 | S1 | S2 | S3 |
|---|---|---|---|---|---|---|
| T08 | Sales → FTP | Forb | A | n/e | A | D |
| T10 | Sales → HR records | Forb | A | n/e | A | D |
| T11 | Sales → router SSH | Forb | A | n/e | D | D |
| T12 | Telnet → router | Forb | A | n/e | A | n/e |
| T13 | HR → ping server | Forb | A | A | A | n/e |
| T16 | Internet → FTP | Forb | A | n/e | D | n/e |
| T19 | Sales → router SSH (2) | Forb | A | n/e | D | n/e |
| T18 | Same-VLAN ping | Ctrl | A | n/e | A | n/e |

*Green = policy goal met · Red = forbidden flow worked or required flow failed · Amber P = partial (FTP login only) · n/e = no screenshot, excluded from counts · S0 has no rules, so every flow should work*

# Results: access fell as rules grew




Stage 1

**2 of 2** forbidden flows worked

Stage 2

**4 of 8** forbidden flows worked

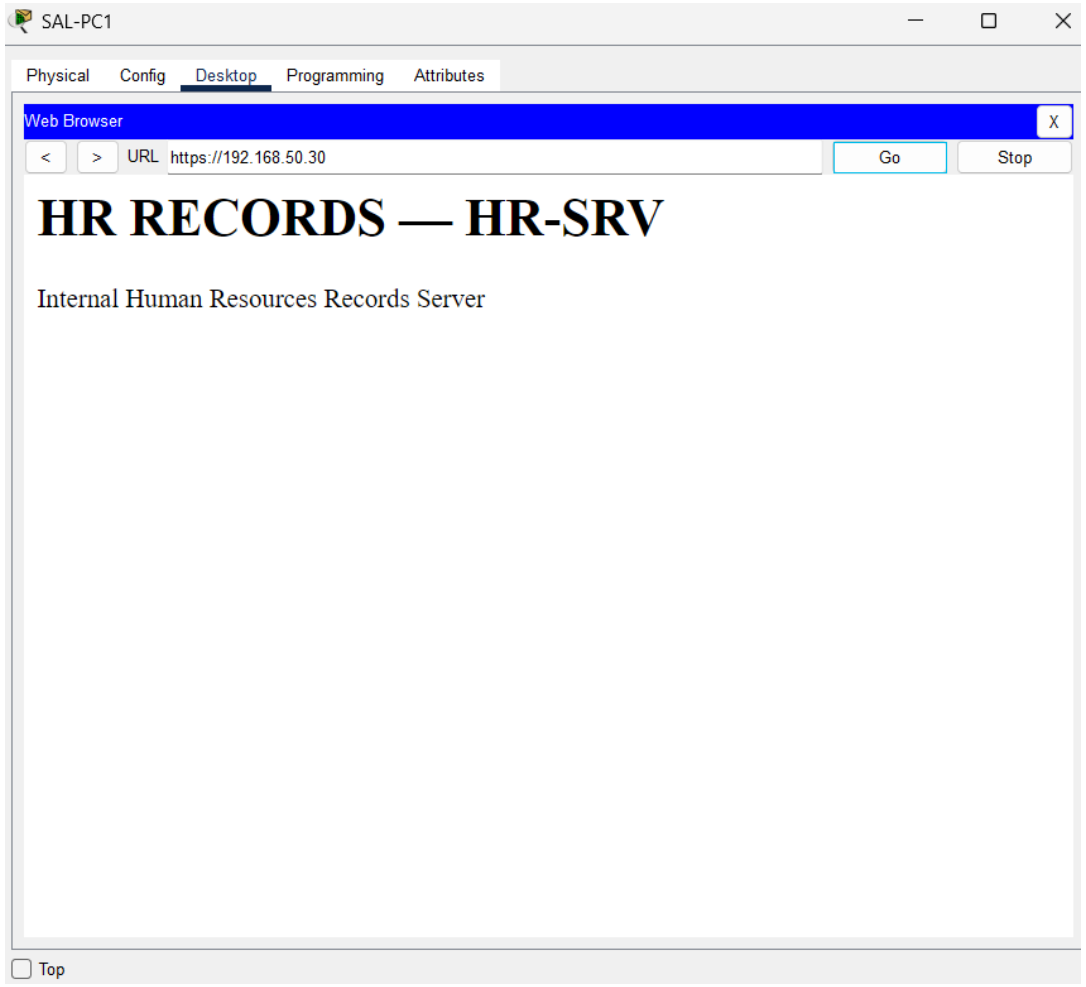
Stage 3

**0 of 4** forbidden flows worked

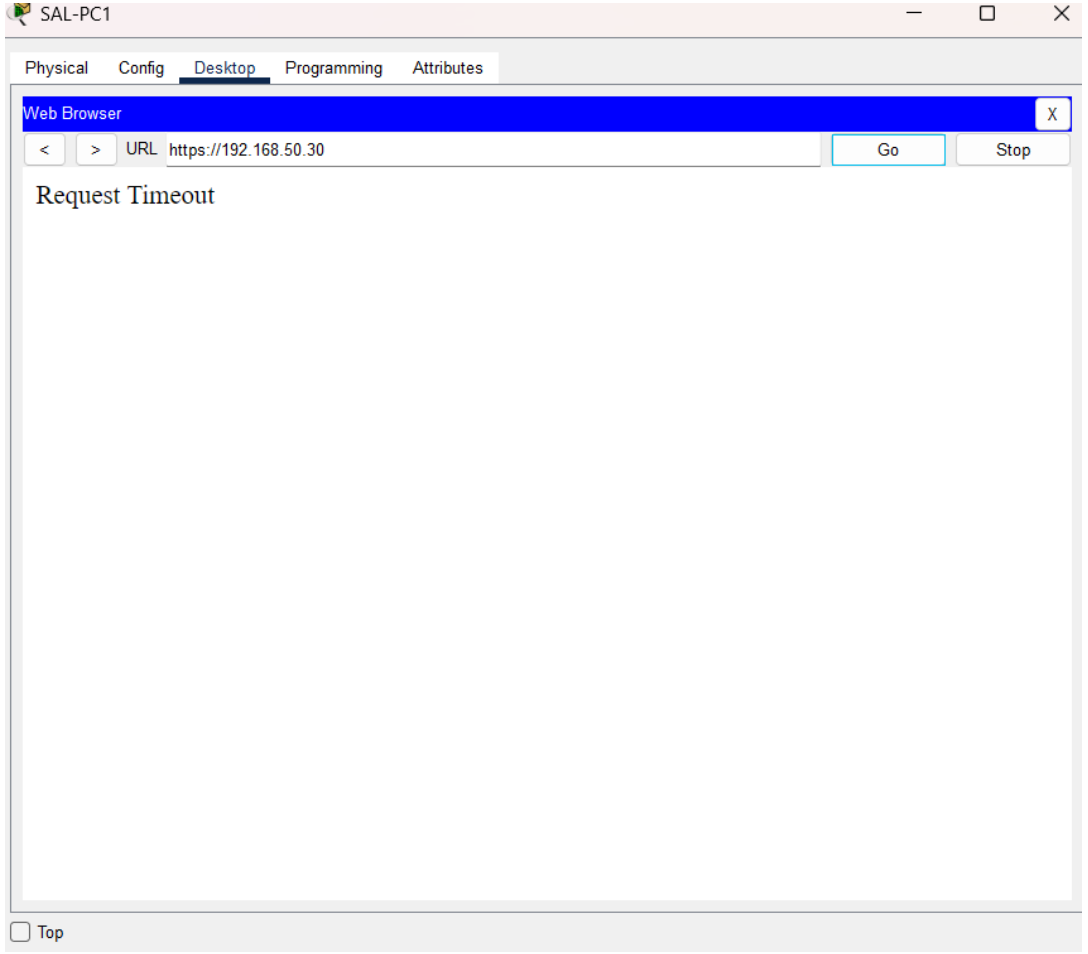
*Counts cover only tests with screenshot evidence, so they are not compared as percentages.*

# Same test, two policies: Sales → HR records (T10)

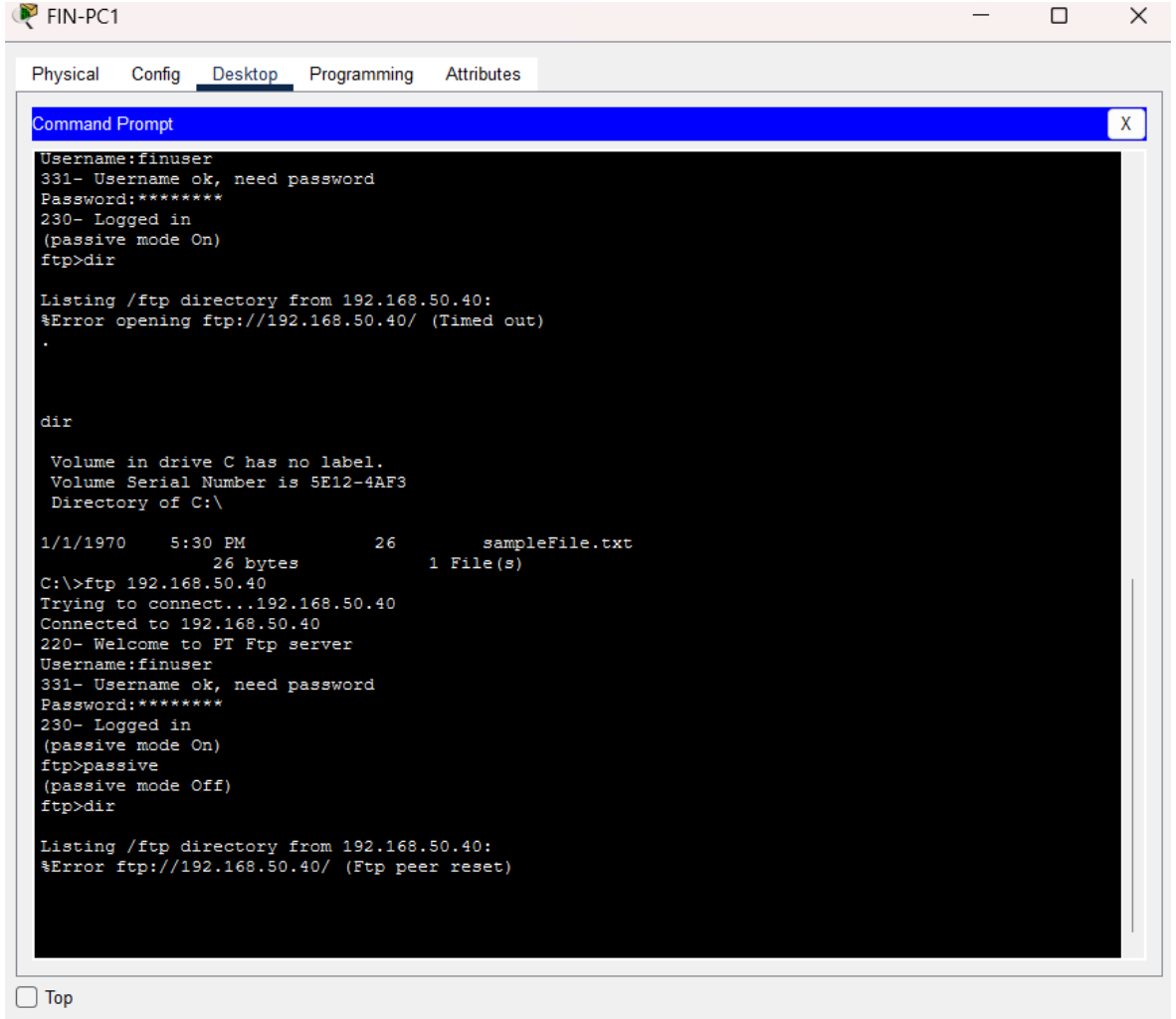
**PERMIT** Stage 2: department rule opens the whole server zone




**DENY** Stage 3: only HR may reach HR-SRV on port 443



# Key finding: least privilege broke a required service




## What happened

Finance could log in to its FTP server, but listing files failed: "Timed out" (passive) and "Ftp peer reset" (active).

## Why

The Stage 3 rule permits only the FTP control port (21). FTP's separate data connection hits the "deny internal" rule.

## So what

Least privilege costs more than rules: multi-connection services need extra, carefully ordered entries.

# Other observations

### Two locks, two symptoms

In Stage 2, Sales SSH to 192.168.40.1 timed out (interface ACL) while SSH to 192.168.50.1 was refused (router login rule): one goal, enforced in two places.

### Rule count can mislead

The Stage 3 edge ACL is the strictest but has the fewest entries (6 → 6 → 5).

### Same-VLAN traffic

HR-PC1 always reached HR-PC2: traffic inside a VLAN never passes the router, so no router ACL can filter it.

### Build issues fixed

A duplicate IP on R-CORE and wrong server addresses were found in Stage 0 and corrected before testing.

# How our results compare with the literature (Part C)

| Observation | Literature | Relation |
|---|---|---|
| Forbidden flows: 2 of 2 → 4 of 8 → 0 of 4 | [3], [5] | Agrees |
| Rules 10 → 25 → 40; order pairs 0 → 9 → 24 | [2] | Agrees in direction |
| Strictest edge ACL has fewest entries | [9], [10] | Agrees: count misleads |
| Department rules still let Sales reach HR data | [4], [15] | Agrees: zone trust too coarse |
| Stage 3 broke FTP file listing | [13] | Partly: adds a concrete usability cost |
| Same-VLAN traffic never filtered | [15], [16] | Agrees: limit of router ACLs |

*We measured reachability and policy structure, not administrator error, so [2] is matched in direction, not proven.*

# Limitations

### Small scale

19 devices and 40 rules, versus large real rule sets

### Evidence gaps

Screenshots for 17 tests in Stage 0, 4 in Stage 1, 14 in Stage 2, 7 in Stage 3

### Not Zero Trust

ACLs see addresses and ports, never user or device identity

### Simulator models

FTP stands in for a database; no NAT, logging or attack traffic

### Not run

Misconfiguration experiments M1 and M2; zero-hit and line-change metrics

### Stateless filter

established accepts any TCP segment with ACK or RST set

# Future work

### Fix the FTP gap

Add one minimal, correctly ordered data-channel rule, or move the finance service to HTTPS/SFTP, and re-test

### Run the mistake experiments

M1 (shadowed rule) and M2 (missing DNS rule) on copies of Stages 2 and 3

### Complete the evidence

Capture every test and ACL counter in every stage; save running configs to measure lines changed

### Stateful and identity-aware

Compare with a stateful firewall and with identity-based microsegmentation (Zero Trust)

# Conclusion



## Security improved

Forbidden access fell from broad to least privilege; all forbidden flows we captured were blocked in Stage 3



## Cost rose

Rules grew 4× and order-dependent pairs from 0 to 24



## Usability suffered

Least privilege broke FTP file listing until the policy is extended

*Write the required flows first, then refine — the trade-off is real, and it can be measured.*

**Thank you · Questions?**

# Key references (1 of 2)


[1] A. Wool, "A quantitative study of firewall configuration errors," Computer, 37(6), 2004.

https://ieeexplore.ieee.org/document/1306389

[2] A. Wool, "Trends in firewall configuration errors," IEEE Internet Computing, 14(4), 2010 (extended version).

https://arxiv.org/abs/0911.1240

[3] K. Scarfone, P. Hoffman, "Guidelines on firewalls and firewall policy," NIST SP 800-41 Rev. 1, 2009.

https://doi.org/10.6028/NIST.SP.800-41r1

[4] S. Rose et al., "Zero trust architecture," NIST SP 800-207, 2020.

https://doi.org/10.6028/NIST.SP.800-207

[5] J. H. Saltzer, M. D. Schroeder, "The protection of information in computer systems," Proc. IEEE, 1975 (full text).

https://www.cs.virginia.edu/~evans/cs551/saltzer/

# Key references (2 of 2)


[9] E. Al-Shaer, H. Hamed, "Discovery of policy anomalies in distributed firewalls," IEEE INFOCOM, 2004.

https://pure.kfupm.edu.sa/en/publications/discovery-of-policy-anomalies-in-distributed-firewalls/

[10] E. Al-Shaer et al., "Conflict classification and analysis of distributed firewall policies," IEEE JSAC, 2005.

https://doi.org/10.1109/JSAC.2005.854119

[11] L. Yuan et al., "FIREMAN: A toolkit for firewall modeling and analysis," IEEE S&P, 2006.

https://doi.org/10.1109/SP.2006.16

[13] A. Voronkov et al., "Systematic literature review on usability of firewall configuration," ACM CSUR, 2017.

https://doi.org/10.1145/3130876

[15] R. Chandramouli, "Guide to a secure enterprise network landscape," NIST SP 800-215, 2022.

https://doi.org/10.6028/NIST.SP.800-215


*Full list of 18 references in the report (IEEE style). Links: DOI where available, otherwise publisher, repository or full-text page.*